

מודול 2 — תרגול ותרchiשים

חומר לימוד

1 יחידות

תוכן העניינים

1. תרגול 🧠 — מודול 2: יסודות Linux

חלק א' — שאלות תרגול

Q1. איזו פקודה מציגה את התיקייה הנוכחית? ואיזו עוברת לתיקיית הבית בשתי דרכים?

Q2. מה ההבדל בין `>` ל- `>>` ?

Q3. פענח את `-rwxr-x---` : מה מותר לבעלים, לקבוצה, לכולם? מה הערך ב-Octal?

Q4. איזו פקודה מוצאת את כל קובצי ה-SUID במערכת, ולמה זה מעניין תוקף?

Q5. מה עושה `sudo -l`, ולמה זו מהפקודות הראשונות אחרי השגת גישה?

Q6. אילו שני קבצים ב- `/etc` הם היעדים החמים ביותר, ומה כל אחד מכיל?

Q7. מה עושה ה-Pipe (`|`)? תן דוגמה שסופרת כמה תהליכי apache רצים.

Q8. נתקעת ב-vim. כיצד יוצאים בלי לשמור?

תשובות

1. `pwd` ; לבית: `cd ~` או `cd /home/<user>` (וגם `cd`).
2. `>` דורס/יוצר קובץ; `>>` מוסיף בסוף בלי לדרוס.
3. בעלים `rwx`, קבוצה `rx`, כולם —; `750` = Octal.
4. `find / -perm -4000 2>/dev/null` ; קובץ SUID בבעלות root רץ בהרשאות root → וקטור הסלמה.
5. מציג אילו פקודות מותר להריץ כ-root; הרשאות `sudo` שגויות = מסלול הסלמה קלאסי.
6. `/etc/passwd` (משתמשים, קריא לכולם), `/etc/shadow` (Hash של סיסמאות, root בלבד).
7. מעביר פלט של פקודה אחת כקלט לשנייה. `ps aux | grep apache | wc -l`.
8. `Esc` ואז `q!` : `Enter`.

חלק ב' — תרחיש מהחיים האמיתיים

“Local Enumeration אחרי פריצה”

השגת Shell כמשתמש רגיל (www-data) על שרת Linux שנפרץ. לפני שתנסה להסלים ל-root, עליך “לסייר” במערכת. **בצע במעבדה שלך (Kali או מכונת מטרה)** את רצף הסיור, ותעד כל פלט:

```
# 1. מי אני ומה ההרשאות שלי
whoami; id; sudo -l

# 2. איזו מערכת זו
uname -a; cat /etc/os-release

# 3. משתמשים אנושיים
grep "bash|sh$" /etc/passwd

# 4. SUID וקטור הסלמה – קובצי
find / -perm -4000 2>/dev/null

# 5. קבצים רגישים שאולי קריאים
ls -la /home/*; cat /etc/passwd
```

המשימה: לאחר ההרצה, ענה — מהם **שלושת** הממצאים שהיו הכי מבטיחים אילו היית תוקף, ולמה?

פתרון מנחה

ממצאים מבטיחים אופייניים: 1. **sudo -l עם NOPASSWD** על פקודה כלשהי → הסלמה מיידית ל-root (בדוק ב-GTFOBins). 2. **קובץ SUID חריג** (למשל /usr/bin/find או בינארי מותאם) → ניצול להרצה כ-root. 3. **קובץ קונפיג/סיסמה קריא** ב-/home או /var/www (למשל config.php עם פרטי DB) → Credential Reuse.

 זהו בדיוק מה שעושים בשלב הפוסט-אקספלויטציה (מודול 11). הרגל את הרצף הזה — הוא חוזר בכל מכונה.

 חזרה למודול · תרגילים מעשיים